

IT-Sicherheit

Prof. Dr. Tobias Straub
Masterprogramm Informatik

www.dhbw.de

© 2021 Tobias Straub – eine Nutzung der Unterlagen ist nur den Teilnehmer/innen und ausschließlich für Zwecke der Vorlesung gestattet, jegliche Weitergabe ist untersagt

Inhalt

- Systematik von Bedrohungen [RFC4949]
- Beispiele konkreter Bedrohungen im Netzwerk, siehe auch [Eckert, Kap. 2]
 - Schadsoftware
 - Human Factors

Bedrohungen und Angriffe

- Systematik nach RFC4949 (erläutert auch in [Stallings])
- Unterscheidung je nach Ziel der Bedrohung (threat consequence):

1. Unauthorized Disclosure (unautorisierte Informationsgewinnung)

- *Exposure* (z.B. un/beabsichtigte Weitergabe sensibler Daten)
- *Interception* (Abfangen der Datenübertragung, Datenträger-Diebstahl)
- *Inference* (logisches Schließen, indirekte Informationsgewinnung, z.B. per Verkehrsflussanalyse)
- *Intrusion* (Umgehen von Schutzmechanismen, z.B. durch physisches Eindringen, Reverse Engineering)

2. Deception (Täuschung)

- *Masquerade* (Maskierung, z.B. Spoofing, Trojanisches Pferd)
- *Falsification* (Daten-Manipulation, durch Änderung oder Einfügen)
- *Repudiation* (Abstreiten von Aktionen, z.B. des Sendens/Empfangens von Daten)

Bedrohungen und Angriffe (Forts.)

3. Disruption (Unterbrechung, Störung)

- *Incapacitation* (Systemkomponente untauglich machen, zB. durch
 - Malicious logic / Schadsoftware,
 - physische Zerstörung,
 - Bedienfehler, HW/SW-Fehler, höhere Gewalt)
- *Corruption* (Funktionsweise beeinflussen durch Modifikation der Software oder von Daten, z.B. durch
 - Tampering = gezielte Änderungen am System
 - Malicious logic, Bedienfehler, HW/SW-Fehler, höhere Gewalt)
- *Obstruction* (Behinderung durch Überlastung des Systems oder Störung der Kommunikation)

4. Usurpation (widerrechtliche Aneignung)

- *Misappropriation* ("Unterschlagung", z.B. unautorisierte Nutzung von Systemressourcen, Datendiebstahl)
- *Misuse* (Sicherheitsverstoß durch Missbrauch einer Komponente, z.B. durch Überschreitung der eigenen Berechtigungen)

Beispiele konkreter Bedrohungen im Netzwerk

Layer im OSI-Modell	TCP/IP-Ref.modell	Beispiele für Protokolle	Beispiele für Bedrohungen
“8: User”			Phishing, Social Engineering, ScareWare, Hoax, Identitätsdiebstahl, SPAM
7: Application	Application	HTTP, FTP, IMAP, SMTP, POP, DNS BGP	Spoofing z.B. von E-Mails, Session Hijacking, DNS Amplification Attack, IP Hijacking (BGP), SQL-Injection, XSS, Malware (Viren, Trojanische Pferde, Würmer)
6: Presentation			
5: Session			
4: Transport	Transport	TCP, UDP	SYN-Flood (DoS), Low Orbit Ion Cannon (DDos)
3: Network	Internet	IP, ICMP ARP	IP Address Spoofing, Smurf Attack, IP Fragmentation Attack, Ping of Death
2: Data Link	(Data) Link*	802.3 Ethernet, 802.11 WLAN, LWL	ARP Cache Poisoning
1: Physical	Physical		PRISM

* auch: Network Access

Bezeichnung der Layer im TCP/IP-Referenzmodell nach Stallings und Tanenbaum, z.T. abweichende Benennung, siehe http://en.wikipedia.org/wiki/Internet_protocol_suite

Schadsoftware

Typ	Eigenschaften
Virus	verbreitet sich selbst durch Anhängen an “Wirtsprogramm”
Wurm	verbreitet sich selbständig im Netzwerk
Trojanisches Pferd	enthält (neben nützlicher offensichtlicher Funktionalität) versteckte Zusatzfunktionalität, z.B. Spyware
Logische Bombe, Zeitbombe	Schadfunktion wird unter bestimmten Bedingungen (zu bestimmtem Zeitpunkt) aktiviert
Hintertür (trapdoor)	erlaubt unberechtigte Zugriffe auf Funktionalität

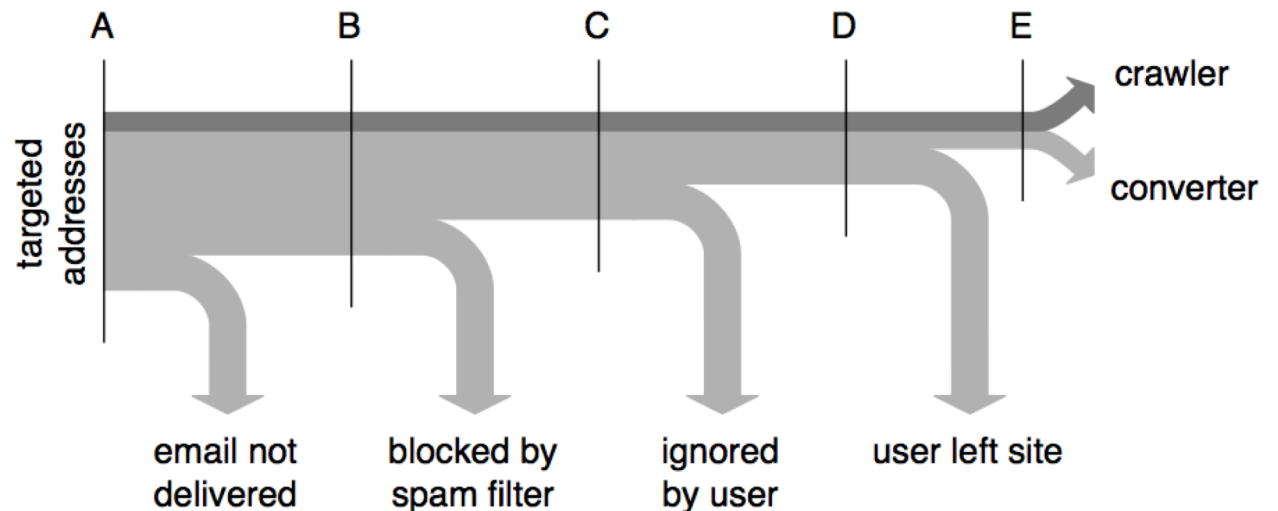
- Verbreitungswege
 - zuletzt wieder stärkere Verbreitung per E-Mail, trotz Spam-Filter
 - häufig per “Drive-By-Download“ über kompromittierte Webseiten: Ausnutzen von Schwachstellen in Betriebssystem, Browser oder Plug-Ins
 - Individualisierung des Codes, daher mit signaturbasierten Ansätzen nicht mehr zuverlässig zu erkennen
 - zusätzlich Fähigkeit zur Verbreitung per USB-Stick oder LAN, präparierte Office- oder PDF-Dokumente, “Überspringen“ auf mobile Geräte

Human Factors

- SPAM
- Ransomware
- Social Engineering
- Scareware
- Phishing

“Order V1agra now!”

- Untersuchung der University Berkeley durch Infiltration eines Botnets
- SPAM-Geschäftsmodell selbst noch lohnenswert bei extrem wenigen Käufern
- 350 Mio. Mails
- 28 Kunden (!)

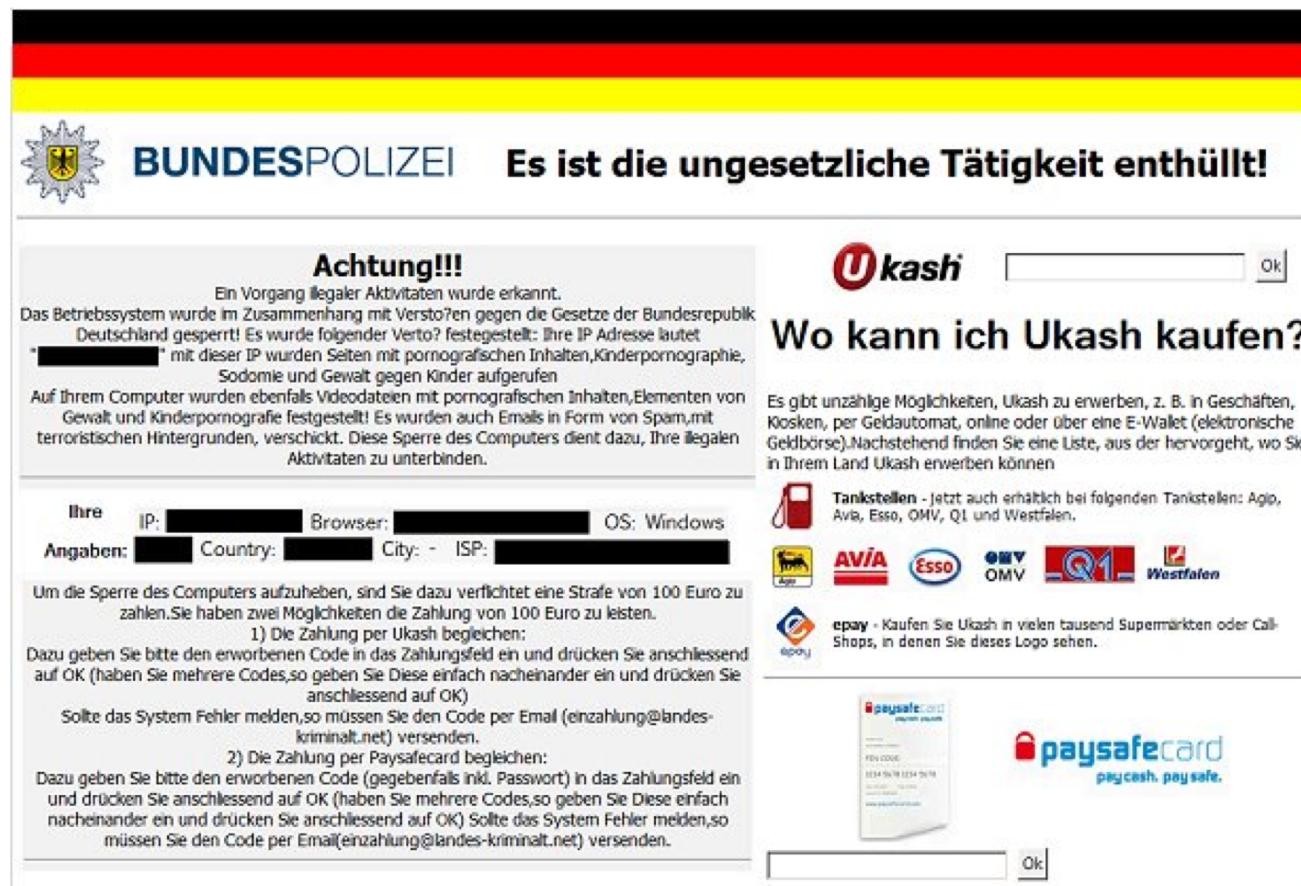


STAGE	PHARMACY		The spam conversion pipeline.
<i>A</i> – Spam Targets	347,590,389	100%	
<i>B</i> – MTA Delivery (est.)	82,700,000	23.8%	
<i>C</i> – Inbox Delivery	—	—	
<i>D</i> – User Site Visits	10,522	0.00303%	
<i>E</i> – User Conversions	28	0.0000081%	

[Quelle: <http://www.icsi.berkeley.edu/pubs/networking/2008-ccs-spamalytics.pdf>]

Ransomware klassisch: BKA-Trojaner & Co.

- schon vor Jahren: „Bundespolizei-Virus“, „BKA-Trojaner“ sperren Bildschirm
- schränkt Zugriff auf Daten und System ein und fordert „Lösegeld“
- kein Datenverlust, Rechner kann von Rettungssystem gestartet werden



[Grafik: <http://www.redirect301.de/bundespolizei-trojaner-entfernen.html>]

Ransomware moderner

- „Krypto-Trojaner“ (auch: Verschlüsselungs-Trojaner, Cryptoware), z.B. WannaCry, Locky, TeslaCrypt, ...



[Grafik: <https://www.tagesspiegel.de/weltspiegel/wanna-cry-bka-uebernimmt-ermittlungen-nach-weltweiter-cyber-attacke/19797084.html>]

Analyse Krypto-Trojaner

- Betriebssystem lässt sich aber weiterhin starten, aber Verschlüsselung von
 - lokalem Laufwerk, z.T. auch USB- oder Netzlaufwerke
 - alle Dokumente, Fotos etc. (Dateitypen Locky s.u.)
 - ursprüngliche Dateien gelöscht, z.T. auch Volumenschattenkopie
- Drohungen:
 - stufenweise Erhöhung Lösegeld
 - oder Löschung einer gewissen Zahl von Dateien pro Stunde
- Lösegeld per Bitcoin, Bezahlkarten (Paysafecard, Ukash)
- Einfallstor für WannaCry: „Eternal Blue“ (Lücke in SMB-Protokoll, von NSA entdeckt und jahrelang genutzt)

```
.123 .3dm .3ds .3g2 .3gp .602 .7z .aes .arc .asc .asf .asm .asp .avi .bak .bat .bmp .brd .cgm .class .cmd .cpp .crt  
.cs .csr .csv .db .dbf .dch .dif .dip .djv .djvu .doc .docb .docm .docx .dot .dotm .dotx .fla .flv .frm .gif .gpg .gz .hwp  
.ibd .jar .java .jpeg .jpg .js .key .lay .lay6 .ldf .m3u .m4u .max .mdb .mdf .mid .mkv .mml .mov .mp3 .mp4 .mpeg  
.mpg .ms11 .myd .myi .nef .odb .odg .odp .ods .odt .otg .otp .ots .ott .p12 .paq .pas .pdf .pem .php .pl .png .pot  
.potm .potx .ppam .pps .ppsm .ppsx .ppt .pptm .pptx .psd .qcow2 .rar .raw .rb .RTF .sch .sh .sldm .sldx .slk .sql  
.sqlite3 .Liedtitel .stc .std .sti .stw .svg .swf .sxc .sxd .sxi .sxm .sxw .tar .tar.bz2 .tbk .tgz .tif .tiff .txt .uop .uot .vb  
.vbs .vdi .vmdk .vmx .vob .wav .wb2 .wk1 .wks .wma .wmv .xlc .xlm .xls .xlsb .xlsm .xlsx .xlt .xltn .xltx .xlw .xml  
.zip
```

Ransomware – Verschlüsselung

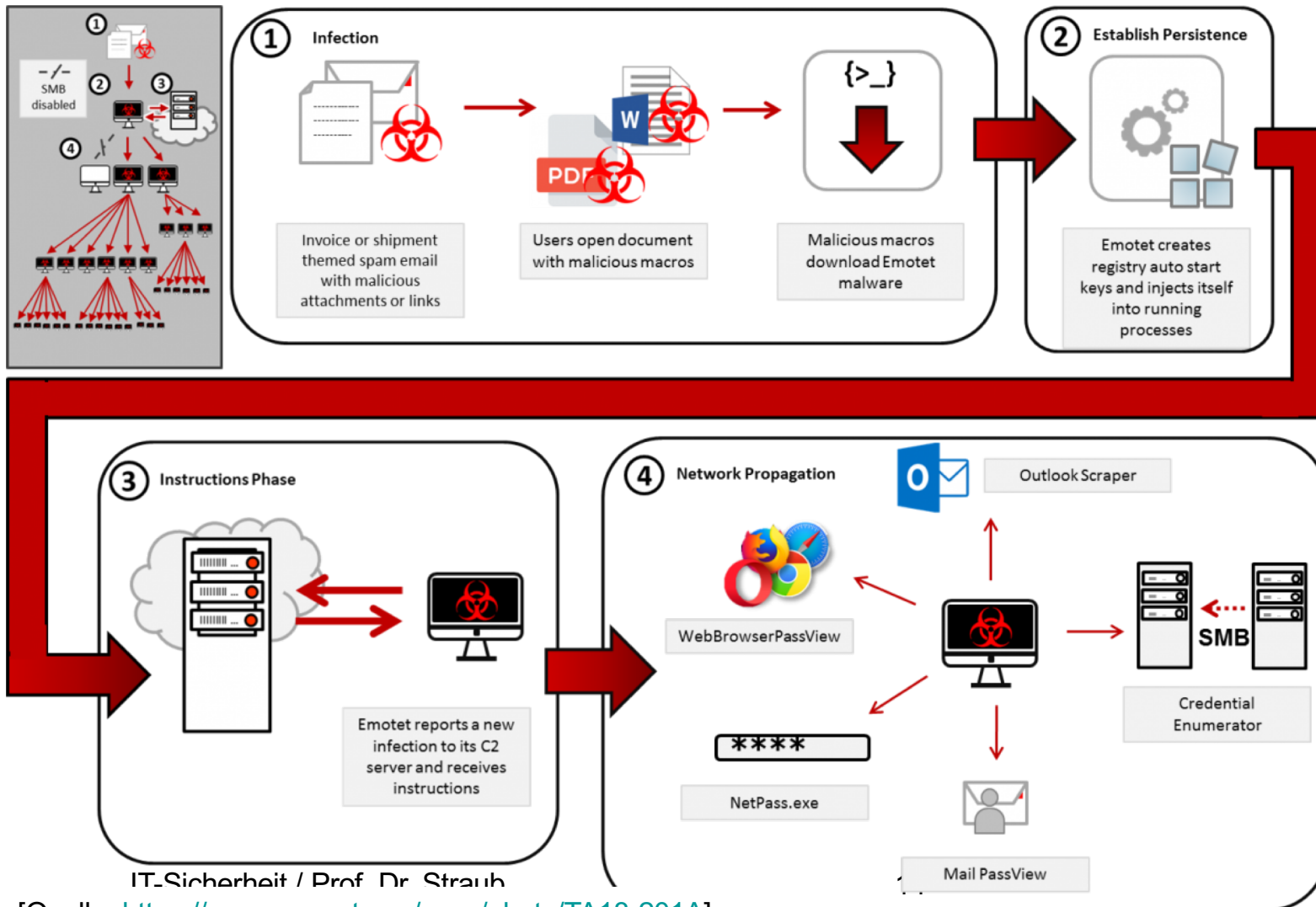
- i.d.R. hybride Verschlüsselung:
 - symmetrische Verschlüsselung von Daten (z.B. per AES, RC4)
 - asymmetrisches Verfahren für Schlüsselaustausch (z.B. RSA, ECDH)
- Variante 1:
 - Erzeugung eines Schlüsselpaars auf infiziertem System
 - Private Key auf Steuerungs-Server des Angreifers hinterlegen
 - Public Key für Daten-Verschlüsselung verwenden (mit symm. Session Keys)
- Variante 2:
 - Schadprogramm enthält bereits Public Key des Angreifers
 - kein Schlüsselaustausch mit Steuerungs-Server erforderlich
- z.T. sind Entschlüsselungstools vorhanden; bei korrekter Implementierung ist jedoch keine Entschlüsselung ohne passenden Private Key möglich

Ransomware – Verbreitung

- i.d.R. unspezifische Massenangriffe, selten Hinweise auf gezieltes Vorgehen
- **Angriffsvektoren:**
 - meist als *Mail-Anhang* (Office Dokumente mit Makros, Archive ggf. mit Passwort, Programm- oder Skriptdateien), der „Dropper“ enthält (dieser lädt eigentlichen Schadcode nach, lässt sich leicht modifizieren, um Erkennung zu erschweren)
 - *Drive-by-Downloads*: Umleitung des Browsers (per iframe oder schädlichem Werbebanner) auf Exploit-Kit, welches Schwachstellen in Browser, Plug-Ins oder Betriebssystem ausnutzt
 - Schwachstellen in *Server-Software* (z.B. CMS oder Shop System)
 - *Nachladen* bei schon bestehenden Infektion mit Bot
- **Betroffene:** 32% der auf BSI-Anfrage antwortenden Unternehmen, möglich:
 - Betriebsbeeinträchtigungen (bei 2% sogar existenzgefährdend)
 - Reputationsverlust
 - Fremdschäden, wenn vertragliche Verpflichtungen gg.über Dritten nicht erfüllt werden können (potenziell hoch bei kritischen Infrastrukturen)

Beispiel: Emotet

- ursprünglich "Banking-Trojaner", kann aber Schadfunktion nachladen
- Verbreitung durch authentisch gemachte Mails dank "Outlook-Harvesting"



- Passwörter ermitteln aus System, Browser, Mail-Client
- E-Mail-Adressen abgreifen
- schreibbare Windows-Fileshares suchen bzw. Passwörter hierfür cracken

Master Informatik, TM40304

Ransomware – begünstigende Faktoren und Ausblick

- **Versäumnisse bei Prävention:**
 - fehlende *Mitarbeiter-Sensibilisierung* und nicht umgesetzte technische Schutzmaßnahmen
-> Anfälligkeit für SPAM-Wellen
 - fehlende *Sicherheitsupdates*, ungenügendes *Patch-Management*
-> Erfolgswahrscheinlichkeit für Drive-By-Angriffe steigt
 - fehlende *Netzsegmentierung*, umfangreiche Freigaben und schwache Admin-Passwörter
-> größeres Ausmaß des Schadens
 - unzureichendes *Backup-Konzept*
-> größerer Zeitraum des Datenverlusts
- **Ransomware ist „Erfolgsmodell“** für Kriminelle, welches sich auf gezielte Angriffe ausweiten lässt, um höhere Summen zu erpressen:
 - Infiltration einer Organisation
 - Identifizierung der gespeicherten Daten und Backups
 - zeitlich koordinierte Verschlüsselung, dann
 - Daten kopieren (Spionage), löschen (Sabotage), verschlüsseln (Erpressung)

Social Engineering

- „Euphemism for non-technical or low-technology methods, often involving trickery or fraud, that are used to attack information systems.“ [RFC4949]
- Angreifer gibt sich Mitarbeitern gegenüber als Administrator oder höherer Vorgesetzter aus, vorzugsweise per Telefon
- beschafft sich im Vorfeld Informationen über das Umfeld (firmen-spezifische Systeme, Abläufe, „Slang“), klingt damit glaubwürdiger
-> Recherche auf Webseite, sozialen Netzen nach pers. Angaben der Mitarbeiter
- Opfer wird dazu gebracht, Informationen preiszugeben oder Aktionen auszuführen (z.B. Installation von Software, Passwort-Änderung), nutzt etwa
 - Hilfsbereitschaft, Dankbarkeit
 - Gutgläubigkeit, Respekt vor Autoritäten
 - weibliche Attraktivität ;-)-> „Robin Sage“
- Buchtipp: Kevin Mitnick: „The Art of Deception“

Social Engineering – Beispiele



Kunstfigur Robin Sage

- Accounts in sozialen Netzen wie LinkedIn
- angebliche MIT-Absolventin und IT-Sicherheitsspezialistin beim US-Militär
- kontaktiert gezielt IT-Sicherheitsexperten, Militär- und Geheimdienstmitarbeiter
-> 300 “Freunde” innerhalb eines Monats
- Glaubwürdigkeit durch bekannte hochrangige “Freunde” im Profil
- erhält diverse einschlägige Job-Angebote und vertrauliche Informationen

Details: T. Ryan “Getting In Bed with Robin Sage.”, BlackHat 2010

- Was sind interessante Informationen?

[[Defcon 20: Social Engineering CTF](#)]

Can Be Used for Onsite Pretext	
Do you have a cleaning/janitorial service?	5
What is the name of the cleaning/janitorial service?	7
Company Wide Tech	Pts
What operating system is in use?	10
What service pack/Version?	15
What program do they use to open PDF documents and what version?	10
What browser do they use?	10
What version of that browser?	15
What mail client is used?	10
What version of the mail client?	10
Fake URL(getting the target to go to a URL)	25

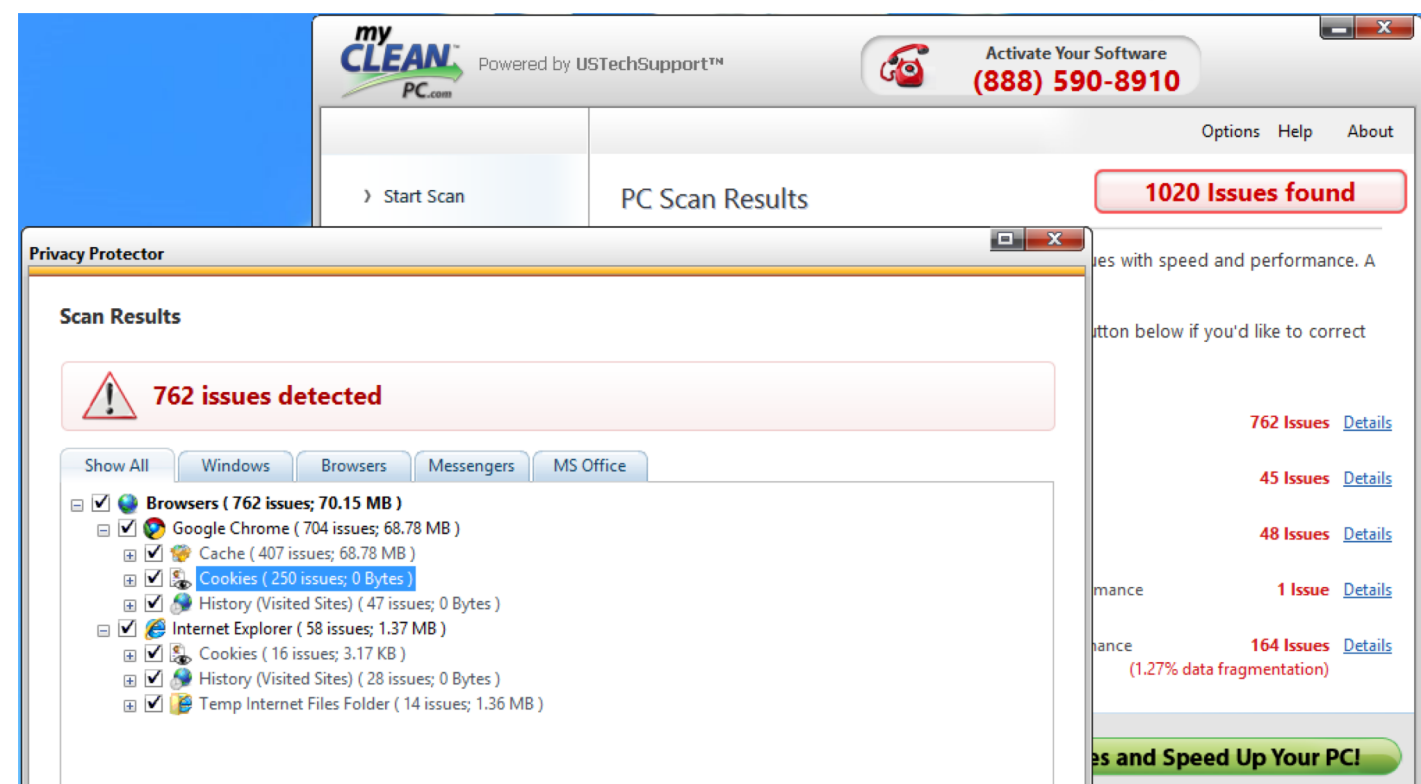
[Quelle: <http://www.washingtontimes.com/news/2010/jul/18/fictitious-femme-fatale-fooled-cybersecurity/?page=1>]

Bsp: Scareware

- www.myCleanPC.com im Fernsehen beworben
- zur Beseitigung der gefundenen “issues” ist kostenpflichtige Version erforderlich, z.B. Löschen von:
 - Cookies
 - Browser Cache
 - Browser History

3 Easy Steps - Download, Diagnose, Speed Up Your Computer!

- 1** 
Download and install the MyCleanPC free diagnosis in minutes.
- 2** 
Run your FREE diagnosis to find out what may be slowing down your computer.
- 3** 
Activate software for just \$19.99 to optimize your computer performance. Our technicians can also help activate your software.



The screenshot shows the myCleanPC interface. At the top, it says "my CLEAN PC.com Powered by USTechSupport™". Below this, there's a "Start Scan" button and a "PC Scan Results" section. A red banner indicates "1020 Issues found". The "Privacy Protector" window is open, showing "Scan Results" with a warning icon and "762 issues detected". The results are categorized by application: Browsers (762 issues; 70.15 MB), Google Chrome (704 issues; 68.78 MB), Cache (407 issues; 68.78 MB), Cookies (250 issues; 0 Bytes), History (Visited Sites) (47 issues; 0 Bytes), Internet Explorer (58 issues; 1.37 MB), Cookies (16 issues; 3.17 KB), History (Visited Sites) (28 issues; 0 Bytes), and Temp Internet Files Folder (14 issues; 1.36 MB). On the right side, there's a list of issues with links to details: 762 Issues, 45 Issues, 48 Issues, 1 Issue, and 164 Issues (1.27% data fragmentation). At the bottom, there's a green button that says "Speed Up Your PC!".

[Quelle: <http://arstechnica.com/gadgets/2013/01/yes-that-pc-cleanup-app-you-saw-on-cable-tv-at-3am-is-a-scam/>]

Phishing

- Spezialfall eines Maskierungs-Angriffs:
 - Angreifer gibt sich als legitime Webseite (Bank etc.) aus, auf die er Opfer mit gefälschter E-Mail lockt
 - für Benutzer ist die Authentizität von E-Mails oft nicht zuverlässig zu erkennen, Firmen setzen z.B. selten digitale Signaturen ein
 - > selbst ausprobieren: "Phishing-IQ-Tests":
<https://www.sonicwall.com/phishing-iq-test/>
<https://www.phishingbox.com/phishing-iq-test>
- „Trends“:
 - **Pharming**: Eintrag in hosts-Datei, DNS-Server korrumpieren, Drive-By-Pharming: Änderung der DNS-Server-Einstellungen im Router
 - **„Spear Phishing“**: gezielter Angriff, der höhere Erfolgsquote verspricht, z.B. Mail an Mitarbeiter einer Firma
 - **Man-In-The-Browser** (siehe nächste Folie)
 - Baukasten „Rock Phish Kit“ für hohen Anteil der Angriffe verantwortlich, aufwändige Infrastruktur zur Gewährleistung von „Ausfallsicherheit“
 - kompromittierte PCs dienen als Proxies und verschleiern Webseite des Angreifers; Proxies lassen sich aufgrund großer Zahl nicht ausschalten
 - Fast-Flux-Botnets: Angreifer betreiben eigenen DNS-Server, der schnell wechselnde IP-Adressen zurückgibt (Round-Robin), "Bullet Proof Domains"

Man-In-The-Browser

- mittlerweile erfolgen Phishing-Angriffe meist über Trojanische Pferde
- Man-In-The-Browser ist MITM-Angriff:
 - Browser-Erweiterungen, Skripte etc. modifizieren geladene Original-Seite, bevor sie angezeigt wird
 - eingegebene Passwörter, PINs, TANs etc. werden an Seite des Angreifers gesendet oder Parameter wie z.B. Kontonummer geändert
 - für Original-Seite wirkt Anfrage authentisch (da durchgängig dieselbe IP-Adresse und derselbe Browser)
 - möglicherweise verräterische Antwort der Original-Seite wird angepasst, so dass der Benutzer keinen Verdacht schöpft
 - Authentifikation auch mit Client-Zertifikaten oder Einmalpasswörtern schützt nicht, zweiter vertrauenswürdiger Kanal (SMS mit Überweisungsdaten) dagegen schon, es sei denn:
- Man-In-The-Mobile: Angriff auf mTAN